

Handover: Chức năng Quên Mật Khẩu + Đổi Mật Khẩu (User, Organizer và Admin)

1) Phạm vi và mục tiêu

Tài liệu này mô tả đầy đủ luồng chạy thực tế của chức năng:

- Quên mật khẩu tại form đăng nhập.
- Đăng nhập lại bằng mật khẩu mới được cấp qua email.
- Điều hướng bước vào profile/setting sau khi reset mật khẩu.
- Đổi mật khẩu chủ động trên profile/setting của user, organizer và admin.

Phạm vi triển khai:

- FE sử dụng API BE có sẵn.
- Không mở rộng thêm endpoint mới cho tính năng này.
- Luồng đổi mật khẩu sau login dùng chung `PUT /api/user/profile`.

2) Ví trí code liên quan

FE

- `FE/src/components/auth/LoginModal.tsx`
- `FE/src/services/authService.ts`
- `FE/src/services/axiosClient.ts`
- `FE/src/utils/auth.ts`
- `FE/src/layouts/ClientLayout.tsx`
- `FE/src/pages/client/ProfilePage/index.tsx`
- `FE/src/pages/organizer/ProfilePage/index.tsx`
- `FE/src/pages/admin/SettingPage/index.tsx`
- `FE/src/App.tsx`

BE

- `BE/app.js`
- `BE/routes/userRoutes.js`
- `BE/controllers/userController.js`
- `BE/middleware/auth.js`
- `BE/models/User.js`
- `BE/services/emailService.js`

3) Tổng quan nghiệp vụ

1. Người dùng bấm `Quên mật khẩu?` trong `LoginModal`.
2. FE mở popup nhập email và gọi `POST /api/user/forgot-password`.

3. BE tạo một mật khẩu ngẫu nhiên mới, hash rồi lưu vào DB, sau đó gửi mật khẩu mới qua email.
 4. FE lưu email vừa reset vào `sessionStorage` với key `forgot_password_email_forced_profile`.
 5. Người dùng đăng nhập lại bằng mật khẩu mới nhận được trong email.
 6. Sau login thành công, FE so sánh email đăng nhập với email vừa reset:
 - user -> điều hướng `/profile`
 - organizer -> điều hướng `/organizer/profile`
 - admin -> điều hướng `/admin/settings`
 7. Tại trang profile/setting, người dùng bấm `Đổi mật khẩu` và gọi `PUT /api/user/profile` để đặt lại mật khẩu mới của riêng mình.
-

4) Sequence diagram

4.1 Sequence: quên mật khẩu -> đăng nhập lại -> force vào profile/setting



Syntax error in text
mermaid version 11.14.0

4.2 Sequence: đổi mật khẩu trên profile/setting



Syntax error in text
mermaid version 11.14.0

5) Luồng chạy chi tiết theo thứ tự thực thi

5.1 Khi người dùng bấm `Quên mật khẩu?`

Đi vào FE

- File: `FE/src/components/auth/LoginModal.tsx`
- Nut `Quên mật khẩu?` chỉ có tác dụng mở popup forgot bằng `setForgotOpen(true)`.
- Popup forgot dùng 1 `Form` riêng (`forgotForm`) để submit email.

Khi người dùng bấm nút trong popup

- `Modal.onOk` gọi `forgotForm.submit()`.

- `forgotForm` được gan `onFinish={handleForgotPassword}`.
- Tại đây hàm `handleForgotPassword(values)` được thực thi.

Công dụng của `handleForgotPassword`

- Bật loading cho popup forgot.
- Gọi `forgotPasswordAPI(values)`.
- Nếu thành công:
 - lưu email đã normalize vào `sessionStorage`
 - set email đó lại vào form login chính
 - reset forgot form
 - đóng popup forgot
- Nếu thất bại:
 - hiện message lỗi từ API nếu có

5.2 FE gọi API nào

Service FE

- File: `FE/src/services/authService.ts`
- `forgotPasswordAPI(data)` gọi POST `/api/user/forgot-password`
- `loginAPI(data)` gọi POST `/api/user/login`

Axios client

- File: `FE/src/services/axiosClient.ts`
- Cấu hình `baseURL` cho mọi request.
- Với API cần đăng nhập như PUT `/api/user/profile`, interceptor sẽ tự gán `Authorization: Bearer <token>`.

5.3 Backend xử lý POST `/api/user/forgot-password`

Đi qua app và route

- `BE/app.js` mount `userRoutes` tại prefix `/api/user`.
- `BE/routes/userRoutes.js` map endpoint `/forgot-password` vào controller `getNewPassword`.

Công dụng của `getNewPassword`

File: `BE/controllers/userController.js`

Thu xử lý:

1. Lấy `email` từ `req.body`.
2. Tìm user bằng `User.findOne({ email })`.
3. Nếu không tìm thấy, trả 404 với message `Email không tồn tại`.
4. Nếu tìm thấy:
 - tạo mật khẩu mới ngẫu nhiên 8 ký tự

- hash bang `bcrypt.hash(...)`
- gan lai `user.password`
- `await user.save()`

5. Goi `sendNewPassword(...)` trong `BE/services/emailService.js` de gui email chua mat khau moi.
6. Tra 200 cho FE neu gui email thanh cong.

Cong dung cua `sendNewPassword`

- Dung `nodemailer`.
- Gui email den dung dia chi `cusEmail`.
- Noi dung email co mat khau moi va huong dan dang nhap lai de doi mat khau.

5.4 FE lam gi sau khi forgot-password thanh cong

File: `FE/src/components/auth/LoginModal.tsx`

Sau khi API forgot-password thanh cong, FE lam 4 viec lien tiep:

1. Luu email da reset vao `sessionStorage` voi key `forgot_password_email_forced_profile`.
2. Hien thong bao thanh cong cho nguoi dung.
3. Tu dong dien email vao form login chinh.
4. Dong popup forgot de nguoi dung dang nhap lai.

Muc dich cua `sessionStorage` la danh dau rang lan login tiep theo voi email nay can duoc uu tien dua vao profile/setting de doi mat khau ngay.

5.5 Khi nguoi dung dang nhap lai bang mat khau moi

FE bat dau tai dau

- Van o `FE/src/components/auth/LoginModal.tsx`
- Form login chinh submit vao ham `onFinish(values)`.

`onFinish(values)` lam gi

1. Goi `loginAPI(values)`.
2. Nhan JWT token tu backend.
3. Goi `saveToken(token)` trong `FE/src/utlis/auth.ts` de luu token.
4. Dung `getUserRole()` de lay role tu payload token.
5. Neu la organizer, FE con goi them `getAllOrganizersAPI()` de map `userId` -> `organizerId` va luu `localStorage`.
6. Doc email da luu trong `sessionStorage`.
7. So sanh email vua login voi email vua reset.

Neu dung la login sau reset

- Xoa key trong `sessionStorage` de luong force chi chay 1 lan.
- Dieu huong theo role:

- user -> /profile
- organizer -> /organizer/profile
- admin -> /admin/settings
- Hien thong bao nhac doi mat khau.
- Goi `onLoginSuccess({ skipPendingRedirect: true })`.

Tai sao can `skipPendingRedirect`

- File: `FE/src/layouts/ClientLayout.tsx`
- Layout nay co co che `pendingRedirect` de dua user toi trang ho tung muon vao sau khi login.
- Trong case reset password, uu tien cao nhat la vao profile/setting de doi mat khau.
- Vi vay `skipPendingRedirect=true` se xoa bo redirect tam truoc do, tranh viec vua dang nhap xong bi day sang trang khac.

5.6 Backend xu ly `POST /api/user/login`

Route

- `BE/routes/userRoutes.js` map `/login` -> `loginUser`.

Controller `loginUser`

File: `BE/controllers/userController.js`

Thu tu xu ly:

1. Lay `email`, `password` tu `req.body`.
2. Goi `User.findOne({ email }).select('+password')`.
3. Phai dung `.select('+password')` vi trong `BE/models/User.js`, field `password` duoc khai bao `select: false`.
4. So sanh mat khau bang `bcrypt.compare(...)`.
5. Neu dung:
 - set `user.isActive = true`
 - await `user.save()`
 - tao JWT chua `id`, `email`, `role`
 - tra token cho FE

5.7 Route nao duoc mo sau login

File: `FE/src/App.tsx`

Route duoc force mo sau login bang mat khau reset:

- user -> /profile
- organizer -> /organizer/profile
- admin -> /admin/settings

Tat ca cac route nay deu duoc boc boi `ProtectedRoute`, nghĩa là:

- phải có token hợp lệ
 - phải dùng role mới vào được trang
-

5.8 Khi người dùng bấm **Đổi mật khẩu**

Vị trí form đổi mật khẩu

- User: `FE/src/pages/client/ProfilePage/index.tsx`
- Organizer: `FE/src/pages/organizer/ProfilePage/index.tsx`
- Admin: `FE/src/pages/admin/SettingPage/index.tsx`

Hành vi UI

- Ban đầu form đổi mật khẩu bị ẩn.
- Bấm **Đổi mật khẩu** -> `setShowChangePassword(true)`.
- Form validate:
 - bắt buộc nhập
 - tối thiểu 6 ký tự
 - confirm phải giống password

Khi submit form đổi mật khẩu

- Hàm `handleChangePassword(values)` được gọi.
 - FE gọi `axiosClient.put('/api/user/profile', { password: values.password.trim() })`.
-

5.9 Backend xử lý **PUT /api/user/profile**

Route

- `BE/routes/userRoutes.js`
- Endpoint này đi qua `verifyToken` trước khi vào `updateUser`.

verifyToken làm gì

File: `BE/middleware/auth.js`

Thu tu xử lý:

1. Lấy token từ header `Authorization`.
2. `jwt.verify(token, SECRET_KEY)`.
3. Tìm user từ DB để kiểm tra `isActive`.
4. Nếu hợp lệ, gán `req.user = decoded`.
5. `next()` để vào controller.

updateUser làm gì

File: `BE/controllers/userController.js`

Thu tu xử lý:

1. Neu route la `/profile`, controller lay `userId = req.user.id`.
2. Neu payload co `password`, hash lai bang `bcrypt.hash(...)`.
3. Goi `User.findByIdAndUpdate(userId, req.body, { new: true, runValidators: true })`.
4. Tra user da cap nhat ve FE.

Tai sao user doi mat khau cua chinh ho

- Vi `userId` khong lay tu input FE trong route `/profile`.
- No lay truc tiep tu token da xac thuc.
- Nghia la moi user chi doi duoc mat khau cua tai khoan dang dang nhap.

6) Danh sach API da dung va cong dung

6.1 POST `/api/user/forgot-password`

Vi tri API trong BE

- Route: `BE/routes/userRoutes.js`
- Controller: `BE/controllers/userController.js`
- Ham: `getNewPassword`

Cong dung

- Nhan `email` tu FE.
- Kiem tra email co ton tai khong.
- Tao mat khau ngau nhien 8 ky tu.
- Hash mat khau moi bang `bcrypt` roi luu vao DB.
- Gui mat khau moi qua email.

Request body

```
{
  "email": "user@example.com"
}
```

Response thanh cong

```
{
  "message": "Mat khau moi da duoc gui den email cua ban"
}
```

Response loi thuong gap

- `404`: Email khong ton tai.
- `500`: Loi he thong hoac gui email that bai.

6.2 POST /api/user/login

Vi tri API trong BE

- Route: `BE/routes/userRoutes.js`
- Controller: `BE/controllers/userController.js`
- Ham: `loginUser`

Cong dung

- Xac thuc email + password.
- Tra JWT token cho FE.

Request body

```
{
  "email": "user@example.com",
  "password": "newRandomPwd"
}
```

Response thanh cong

```
{
  "token": "<jwt_token>"
}
```

6.3 PUT /api/user/profile

Vi tri API trong BE

- Route: `BE/routes/userRoutes.js`
- Middleware: `BE/middleware/auth.js`
- Controller: `BE/controllers/userController.js`
- Ham: `updateUser`

Cong dung

- Cap nhat profile cua user dang dang nhap.
- Khi payload co truong `password`, backend se hash truoc khi luu.

Request body cho doi mat khau

```
{
  "password": "newStrongPassword"
}
```



```
}
```

Noi FE gọi API

- User profile -> `FE/src/pages/client/ProfilePage/index.tsx`
 - Organizer profile -> `FE/src/pages/organizer/ProfilePage/index.tsx`
 - Admin setting -> `FE/src/pages/admin/SettingPage/index.tsx`
-

6.4 GET /api/organizer

Cong dung

- Không phải API cốt lõi của forgot-password.
- Chỉ là bước phụ trong login organizer để map `userId` sang `organizerId`.

Noi FE gọi API

- `FE/src/components/auth/LoginModal.tsx`
 - Chỉ chạy khi role sau login là organizer.
-

7) Cases can test

1. Quên mật khẩu với email hợp lệ của user:

- Nhận email chưa mật khẩu mới.
- Đăng nhập bằng mật khẩu mới.
- Hệ thống vào `/profile`.

2. Quên mật khẩu với email hợp lệ của organizer:

- Nhận email chưa mật khẩu mới.
- Đăng nhập bằng mật khẩu mới.
- Hệ thống vào `/organizer/profile`.

3. Quên mật khẩu với email hợp lệ của admin:

- Nhận email chưa mật khẩu mới.
- Đăng nhập bằng mật khẩu mới.
- Hệ thống vào `/admin/settings`.

4. Quên mật khẩu với email không tồn tại:

- API trả lại 404.
- FE hiển thị message lỗi.

5. Login bình thường, không qua forgot-password:

- Điều hướng giữ nguyên như logic trước đó.

6. Có pending redirect trước đó:

- Nếu vừa login bằng mật khẩu reset, ưu tiên vào profile/setting.
- Không bị redirect sang trang cũ đang chờ.

7. Đổi mật khẩu trên profile user:

- Bấm **Đổi mật khẩu** -> form hiện.
- Confirm sai -> không submit.
- Confirm đúng -> gọi API, báo thành công, đóng form.

8. Đổi mật khẩu trên profile organizer:

- Hành vi giống user.

9. Đổi mật khẩu trên setting admin:

- Hành vi giống user.

8) Lưu ý quan trọng

- Toàn bộ logic trên sử dụng API BE có sẵn.
- Có checkbox vào profile/setting chỉ kích hoạt 1 lần cho email vừa reset vì key **sessionStorage** được xóa sau khi xử lý.
- User, organizer và admin đều đổi mật khẩu qua cùng một endpoint **PUT /api/user/profile**.
- **password** trong model User đang để **select: false**, vì vậy login bắt buộc phải **.select('+password')**.
- Hiện tại backend đổi mật khẩu trong DB trước khi gửi email. Nếu gửi email lỗi, password trong DB đã bị đổi rồi. Đây là hành vi hiện tại của code cần lưu ý khi vận hành.